



# Introducción al Marco Legal y Auditorías de Ciberseguridad



Con la colaboración:



# CIBERSEGURIDAD



Prólogo



# HÍDRICA



# Prólogo

Este curso proporciona una visión integral del **marco legal y regulatorio que afecta a la ciberseguridad en entornos IT y OT**, abarcando normativas europeas clave como **NIS2, GDPR, CER, DORA** y legislación nacional sobre **infraestructuras críticas y ENS**.

Además, se exploran los requisitos y metodologías para realizar **auditorías de ciberseguridad**, con un enfoque práctico orientado a sectores industriales y tecnológicos. El objetivo es capacitar al alumno para **interpretar, aplicar y auditar estos marcos normativos** en organizaciones reales.

# Introducción

## Entender por qué la ciberseguridad es una obligación legal.

- La ciberseguridad ya no es solo una buena práctica.
- Es un requisito legal en múltiples sectores.
- Normativas como NIS2, GDPR, el Esquema Nacional de Seguridad o la Ley de Infraestructuras Críticas exigen que las organizaciones implementen medidas de protección, notifiquen incidentes y gestionen el riesgo digital de forma proactiva.
- No cumplir implica consecuencias legales, reputacionales y económicas. En este curso se analiza el “por qué” normativo que convierte la ciberseguridad en un deber empresarial.

# Diferenciar entre riesgo, obligación y responsabilidad

No todos los conceptos legales implican lo mismo.

- El curso enseña a distinguir entre el “riesgo” (posible daño), la “obligación” (lo que se debe cumplir por ley) y la “responsabilidad” (quién responde si algo falla).
- Esta distinción es clave para saber qué priorizar, qué justificar ante una auditoría y cómo proteger legalmente a la organización.
- Se presentarán ejemplos prácticos aplicados a entornos IT y OT.

# Glosario básico (I)

- **Auditoría:** Proceso sistemático para evaluar si una organización cumple con determinados requisitos o normas.
- **CER (Critical Entities Resilience Directive):** La Directiva CER establece un marco legal europeo para garantizar la resiliencia de entidades críticas ante amenazas tanto físicas como cibernéticas.
- **Ciberresiliencia:** capacidad de una organización para resistir, responder y recuperarse rápidamente de ciberataques o incidentes sin interrumpir sus operaciones críticas.
- **Ciberseguridad:** Conjunto de medidas para proteger sistemas y redes frente a ataques, daños o accesos no autorizados.
- **CRA (Cyber Resilience Act):** Reglamento europeo que establece requisitos de seguridad para productos digitales.
- **Cumplimiento:** Grado en que una organización se ajusta a leyes, normas y regulaciones aplicables.
- **DCS (Distributed Control System):** sistema de control distribuido que gestiona procesos complejos mediante varios controladores interconectados, optimizando el control local y global.

## Glosario básico (II)

**DORA (Digital Operational Resilience Act):** Es un reglamento europeo que establece un marco legal común para garantizar que todas las entidades financieras de la UE puedan resistir, responder y recuperarse frente a incidentes cibernéticos o fallos tecnológicos.

**ENS (Esquema Nacional de Seguridad):** Normativa española para asegurar la protección de sistemas en el sector público.

**Gap analysis:** evaluación que identifica las diferencias entre la situación actual de seguridad y los requisitos normativos o de buenas prácticas, para trazar un plan de mejora.

**GDPR (RGPD):** Reglamento general de protección de datos personales.

**Infraestructura Crítica:** Activos, sistemas o redes esenciales cuya interrupción afectaría gravemente a la sociedad o economía.

**ISA/IEC 62443:** es una serie de normas internacionales que establece requisitos y buenas prácticas para garantizar la ciberseguridad en sistemas de automatización y control industrial (IACS), como los que se usan en entornos OT.

**ISO/IEC 27001:** es una norma internacional que establece los requisitos para implementar, mantener y mejorar un Sistema de Gestión de Seguridad de la Información (SGSI) en cualquier tipo de organización.

## Glosario básico (III)

- **IT (Tecnologías de la Información):** Sistemas orientados a procesar, almacenar y transmitir datos corporativos.
- **Ley PIC:** Ley de Protección de Infraestructuras Críticas en España.
- **NIS2:** Directiva europea sobre seguridad de redes y sistemas de información.
- **OT (Tecnologías de Operación):** Sistemas industriales que controlan procesos físicos (fábricas, plantas energéticas, etc.).
- **PLC (Programmable Logic Controller):** controlador industrial programable que automatiza procesos mediante la ejecución de lógicas predefinidas en tiempo real.
- **SCADA (Supervisory Control and Data Acquisition):** sistema de supervisión y control remoto que recopila datos en tiempo real de equipos industriales y permite su gestión centralizada.
- **Seguridad de la Información:** Protección de la confidencialidad, integridad y disponibilidad de la información, sea digital o física.
- **SGSI (Sistema de Gestión de Seguridad de la Información):** conjunto de políticas, procesos y controles que una organización implementa para proteger su información y gestionar los riesgos de seguridad de forma sistemática y continua.

## Glosario básico (IV)

- **TISAX:** Estándar de seguridad de la información para la industria de automoción.

# Objetivos del Curso



## Objetivo General del Curso

“Dotar de los conocimientos legales, normativos y prácticos necesarios para aplicar, auditar y defender el cumplimiento normativo en entornos IT y OT, desde una perspectiva europea, técnica y estratégica”

# Objetivos específicos del Curso

## Reconocer los actores y normas relevantes.

Desde autoridades nacionales como el INCIBE o el CCN-CERT, hasta organismos europeos como ENISA o la Comisión Europea, el curso presenta los actores clave que definen y supervisan el cumplimiento en ciberseguridad.

También se identifican las normativas más relevantes en función del tipo de organización y sector. El alumno terminará sabiendo quién exige qué, cómo se vigila y qué consecuencias tiene no cumplir.

# Objetivos específicos del Curso

## Conocer el marco legal europeo y nacional en materia de ciberseguridad

El alumno explorará las normativas fundamentales que regulan la ciberseguridad tanto en entornos IT como OT. Se presentará la Directiva NIS2, el Reglamento CRA, el RGPD, el ENS español, la Ley de Infraestructuras Críticas (PIC), así como normativas sectoriales como IEC 62443 o TISAX.

El enfoque será práctico: comprender no solo el contenido legal, sino también su aplicabilidad, obligaciones impuestas, plazos, sanciones y mecanismos de supervisión. Este conocimiento constituye la base para auditar, diseñar e implementar sistemas conforme a la ley, y para anticipar futuros marcos normativos que ya se están gestando.

# Objetivos específicos del Curso

## Diferenciar las exigencias normativas en entornos IT y OT

El curso abordará las diferencias clave entre la aplicación de regulaciones en sistemas IT (informáticos) y OT (industriales). Aunque muchas leyes tienen alcance común, sus prioridades cambian: en IT se protege sobre todo la confidencialidad de los datos, mientras que en OT prima la disponibilidad del servicio y la seguridad física.

Se enseñará cómo aplicar correctamente una normativa en cada contexto, qué excepciones o adaptaciones son necesarias, y cómo auditar cada entorno con sensibilidad al riesgo operativo. Este objetivo es crucial para quienes trabajen en sectores como energía, transporte, agua o manufactura.

# Objetivos específicos del Curso

## Comprender el ciclo completo de cumplimiento normativo

Más allá de conocer la normativa, el alumno aprenderá a gestionar el ciclo de cumplimiento: desde la identificación de requisitos aplicables, hasta su implementación, control, documentación y revisión periódica.

Se explorarán conceptos como el *gap analysis*, el ciclo PDCA, los planes de acción correctiva, las políticas de cumplimiento, y los sistemas de gestión basados en normas como ISO 27001 o IEC 62443.

El objetivo es que el alumno no solo pueda evaluar si se cumple una ley, sino que sepa cómo implantar un modelo de cumplimiento sostenible, replicable y auditable en el tiempo.

# Objetivos específicos del Curso

## Capacitar al alumnado para diseñar y ejecutar auditorías de cumplimiento

El curso proporciona una formación práctica sobre cómo preparar y realizar auditorías reales de cumplimiento. Desde la fase de planificación (definición de objetivos, alcance, recursos y metodología), hasta la recogida de evidencias (entrevistas, revisión documental, análisis técnico), el análisis de los hallazgos y la elaboración del informe. Se trabajará con plantillas reales, casos simulados y checklists adaptados a diversas normativas.

El alumno aprenderá a auditar sistemas tanto en IT como en OT, sabiendo adaptarse a sus particularidades y restricciones, con rigor profesional y sentido crítico.

# Objetivos específicos del Curso

## Aplicar herramientas y metodologías adecuadas para cada entorno

El estudiante conocerá y practicará con herramientas especializadas para evaluar la ciberseguridad según el tipo de entorno.

Para IT, se incluirán escáneres de vulnerabilidades, herramientas de análisis de configuración y documentación.

Para OT, se utilizarán soluciones de monitoreo pasivo, inventariado de dispositivos industriales, revisión de planos de red y gestión de firmware.

El objetivo es que el alumno sepa elegir y aplicar la herramienta adecuada a cada contexto técnico y regulatorio.

# Objetivos específicos del Curso

## Interpretar hallazgos legales/técnicos y comunicar recomendaciones efectivas

Una buena auditoría no termina en la recopilación de evidencias, sino en la redacción de conclusiones claras y útiles. El curso formará al alumno en la redacción de informes técnicos y ejecutivos, en la jerarquización de riesgos y recomendaciones, y en la preparación de entregables entendibles tanto para perfiles técnicos como para directivos.

Se trabajará especialmente en cómo traducir hallazgos complejos en acciones prácticas, justificadas y priorizadas. También se entrenará la capacidad de defender una auditoría ante interlocutores diversos con profesionalidad y objetividad.

# Objetivos específicos del Curso

## Fomentar la cultura del cumplimiento y la mejora continua en la organización

El cumplimiento normativo no debe verse como una obligación puntual, sino como parte de la cultura organizativa. Este objetivo busca capacitar al alumno para impulsar procesos de mejora continua, formar al personal, establecer políticas claras y promover la concienciación en todos los niveles.

Se estudiarán mecanismos para fomentar la colaboración entre IT y OT, así como entre ciberseguridad y departamentos legales o de operaciones.

Una cultura sólida permite responder mejor ante auditorías, incidentes o nuevas exigencias regulatorias.

# Objetivos específicos del Curso

## Reconocer y aplicar buenas prácticas éticas, legales y profesionales del auditor

La función del auditor conlleva una gran responsabilidad: debe ser imparcial, riguroso, confidencial y profesional. El curso incluye un bloque específico sobre ética del auditor, códigos de conducta, conflictos de interés, consentimiento para pruebas, protección de datos personales durante la auditoría y trazabilidad de evidencias.

También se trabajarán otras habilidades (“soft skills”) como la comunicación asertiva, la escucha activa y el respeto al contexto operativo, especialmente relevante en plantas industriales. Esto garantiza auditorías eficaces y aceptadas por todos los implicados.

# Objetivos específicos del Curso

## Estar preparado para adaptarse a las nuevas tendencias regulatorias

El entorno regulatorio de la ciberseguridad evoluciona rápidamente: nuevas normativas como el Reglamento CRA, exigencias sobre inteligencia artificial, requisitos para la cadena de suministro o enfoques de ciber resiliencia empiezan a generalizarse.

El curso prepara al alumno para anticipar y adaptarse a estos cambios, aprender de fuentes confiables (como ENISA, INCIBE, NIST) y mantener una actitud de mejora continua. El objetivo es que el profesional esté listo para seguir siendo competente y útil en un entorno cambiante y exigente.